

ResolvX

Breach Management Policy

Topic-Specific Policy - Breach Risk Assessment & Multi-Jurisdictional Notification

POL-016 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-016
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	Legal
Approver	CISO
Review Cycle	Annual, or upon material regulatory change
Next Review	Q3 2027
Frameworks	GDPR Art. 33/34 · NYDFS 23 NYCRR 500.17 · CCPA (Cal. Civ. Code §1798.82) · ISO 27001:2022 A5.24, A5.26, A5.34

1. Purpose

This Breach Management Policy establishes how ResolvX determines whether a suspected personal data breach requires regulatory notification, and governs that notification across every jurisdiction ResolvX operates in.

The Privacy Programme (POL-006) already defines ResolvX's core breach notification deadlines and maintains the Breach Register, and the Incident Response Plan already defines the operational timeline for GDPR notification. This policy adds the piece that sits before either of those: a structured method for determining breach risk in the first place, the equivalent notification framework for ResolvX's US regulatory exposure, and clear authority for who signs off on the notification decision.

2. Scope

This policy applies to any suspected unauthorized access, disclosure, loss, or destruction of personal data ResolvX processes, across the following jurisdictions:

- European Union / EEA, under GDPR which is governed jointly by this policy and POL-006.
- United States, under NYDFS's cybersecurity regulation and California's breach notification law, plus other US state breach notification statutes where affected individuals reside.

India (DPDP Act 2023 and CERT-In reporting requirements) is intentionally out of scope for this version of the policy as it will be addressed separately once ResolvX finalises its Indian regulatory posture. Framework mapping for that scope will follow in a later revision.

3. Relationship to Existing Documents

- POL-006 (Privacy Programme) : Owns the definition of a personal data breach, the core notification deadlines, and the Breach Register.
- Incident Response Plan : Owns the operational incident timeline, containment, and the GDPR 72-hour clock as a live incident metric.
- This policy (POL-016) : Owns the breach risk assessment methodology (§4), the US notification framework (§5), notification content standards (§6), and sign-off authority (§7).

4. Breach Risk Assessment Framework

POL-006's notification table depends on whether a breach poses "no risk," "risk," or "high risk" to individuals. This policy defines how that determination is actually made, assessed across five factors as soon as a suspected breach is identified:

Factor	Assessment Question
Data sensitivity	Does the affected data include financial account data, government ID numbers, or authentication credentials, versus lower-sensitivity identifiers?
Volume / scale	How many individuals are affected, and does the volume itself increase systemic risk (e.g., enabling large-scale fraud)?
Protection state	Was the data encrypted at rest and in transit, and is there any indication the encryption itself was compromised?
Likelihood of misuse	Is there evidence of actual exfiltration and access by an unauthorized party, versus a containment that occurred before data left ResolvX's control?
Mitigating action taken	What containment occurred, and how quickly as a rapidly contained exposure carries materially lower risk than a prolonged one

The assessment produces a risk rating (No Risk / Risk / High Risk) that maps directly onto POL-006's existing notification table and is documented in the Breach Register regardless of the outcome also including a documented "No Risk" determination, since an undocumented decision not to notify is indistinguishable from a missed obligation during an audit.

5. US Notification Framework

5.1 NYDFS (23 NYCRR Part 500)

Where ResolvX's obligations extend to a client or partner covered by New York's cybersecurity regulation, a Cybersecurity Event meeting the regulation's notice threshold is reported to the New York State Department of Financial Services Superintendent within 72 hours of determination which has the same urgency as the GDPR clock, run in parallel, not sequentially.

5.2 California (Cal. Civ. Code §1798.82) and Other US States

California law requires notification to affected California residents "in the most expedient time possible and without unreasonable delay." Where more than 500 California residents are affected, the California Attorney General is also notified. Other US states where affected individuals reside are assessed on a per-incident basis against that state's own breach notification statute — Legal identifies every applicable state based on the residency of affected individuals and applies the strictest deadline among them, rather than defaulting to California's standard alone.

5.3 Determining Applicable US Jurisdictions

US breach notification law is triggered by the residency of the affected individual, not by where ResolvX operates. As soon as a breach is confirmed to involve US persons' data, Legal identifies every US state of residence represented in the affected data set before finalising the notification plan.

6. Notification Content Requirements

6.1 GDPR Notification Content (Art. 33(3))

A supervisory authority notification includes:

- The nature of the breach, including categories and approximate number of data subjects and records concerned.
- The name and contact details of ResolvX's privacy point of contact (GRC Lead, functioning as DPO-equivalent per POL-006).
- The likely consequences of the breach.
- The measures taken or proposed to address the breach, including measures to mitigate its possible adverse effects.

6.2 US Notification Content

US notifications to affected individuals describe, at minimum: what happened, what information was involved, what ResolvX is doing in response, what the individual can do to protect themselves, and how to contact ResolvX with questions.

7. Notification Sign-Off Authority

A decision not to notify carries real liability, so it is not made informally. Legal and the CISO jointly sign off on every breach risk assessment outcome (§4) before it is considered final and logged in the Breach Register. Where the assessment concludes High Risk in any jurisdiction, the CEO is notified before public or regulator-facing communication proceeds, consistent with the CISO's existing board/client communication authority under the Incident Response Plan.

8. Third-Party / Sub-Processor-Caused Breaches

Where a breach originates at a ResolvX vendor rather than at ResolvX directly, the vendor's contractual notification timeline to ResolvX (per its Data Processing Agreement, tracked under POL-005) typically runs shorter than ResolvX's own regulatory deadline specifically, so ResolvX retains enough time to complete its own assessment and notification. Legal confirms the vendor's contractual notification obligation as an immediate first step upon learning of a suspected vendor-caused breach.

9. Roles & Responsibilities

9.1 Legal

- Owns this policy and leads the multi-jurisdictional notification determination (§5).
- Jointly signs off on every breach risk assessment with the CISO (§7).

9.2 GRC Lead

- Runs the breach risk assessment (§4) and maintains the Breach Register entry, including documented No Risk outcomes.

9.3 CISO

- Jointly signs off on notification determinations and holds communication authority for High-Risk outcomes.

9.4 CEO

- Notified before external communication on any High-Risk determination (§7).

10. Compliance and Enforcement

A notification decision made without the sign-off required under §7, or a failure to run the risk assessment in §4 for a suspected breach, is treated as a control deficiency and logged in the Corrective Action Plan.

11. Document Control

Policy ID	POL-016
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	Legal
Approver	CISO
Review Cycle	Annual, or upon material regulatory change
Next Review	Q3 2027
Framework References	GDPR Art. 33, 34 · NYDFS 23 NYCRR 500.17 · CCPA (Cal. Civ. Code §1798.82) · ISO/IEC 27001:2022 A5.24, A5.26, A5.34 · SOC 2 TSC P6.1
Related Documents	POL-002 (Acceptable Use Policy), POL-005 (Vendor Management Policy), POL-006 (Privacy Programme), POL-015 (Incident Management Policy), Incident Response Plan

Appendix A - Regulatory Notification Template (GDPR Art. 33(3))

Completed by Legal and GRC Lead when notifying a supervisory authority. This template covers the four elements Art. 33(3) requires.

Field	Entry
Notification Date	[Date this notification is submitted]
Breach Reference ID	[Incident ID, per the Breach Register]
Nature of the Breach	[Description of what occurred, systems/data involved, and how it was discovered]
Categories of Data Subjects Affected	[e.g., clients, employees, end users of client platforms]
Approximate Number of Data Subjects	[Number, or best current estimate marked as such]
Categories of Personal Data Records Affected	[e.g., names, contact details, financial account identifiers]
Approximate Number of Records Affected	[Number, or best current estimate marked as such]
Likely Consequences	[Assessed impact to affected individuals, per §4's risk assessment]
Measures Taken or Proposed	[Containment and remediation actions completed or planned]
Measures to Mitigate Adverse Effects	[Actions taken to reduce harm to affected individuals specifically]
Privacy Contact	GRC Lead - [name, email, phone - per DPO-equivalent contact]
Prepared By / Date	[Name / Date]

Appendix B — Affected Individual Notification Letter Template

Base structure for direct notification to affected individuals, satisfying GDPR Art. 34 and the content expectations of US state breach notification statutes (§6.2). Legal reviews and finalises the specific wording before use, especially where a specific state's statute requires particular phrasing.

Subject: Notice Regarding a Data Security Incident Affecting Your Information

Dear [Individual Name],

What Happened

[Plain-language description of the incident, the approximate date it occurred, and the approximate date ResolvX discovered it.]

What Information Was Involved

[Specific categories of the individual's personal data involved. Be precise, not vaguer than what is actually known.]

What We Are Doing

[Containment and remediation steps taken, any regulatory notifications made, and any protective services being offered (e.g., credit monitoring), if applicable.]

What You Can Do

[Specific, actionable steps the individual can take e.g., monitoring statements, placing a fraud alert, changing a password which can be tailored to the data actually involved.]

For More Information

[Contact name/role], [email], [phone number]. [Reference to any applicable regulatory contact, e.g., state Attorney General consumer protection resources, where required by the notifying state's statute.]

Sincerely,

[Name], ResolvX

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		